



# Security Architecture

## TASCO Insurance × VETC Growth Platform — Architecture

iorta TechNXT

Version 1.0 · 07 October 2026

# Contents

1. Scope and security objectives
2. Trust boundaries and data-flow diagram
3. Threat model (STRIDE)
4. Zero Trust principles
5. OWASP Top 10 (2021) control mapping
6. OWASP ASVS L2 summary
7. Identity, authentication, MFA and session management
8. Authorisation: RBAC and ABAC
9. Cryptography and key management
10. Secrets management
11. Input validation, data access and PII handling
12. Security logging, monitoring and audit
13. Secure SDLC: scanning in CI
14. Penetration-test readiness checklist
15. Findings register and remediation plan
16. Security incident response outline

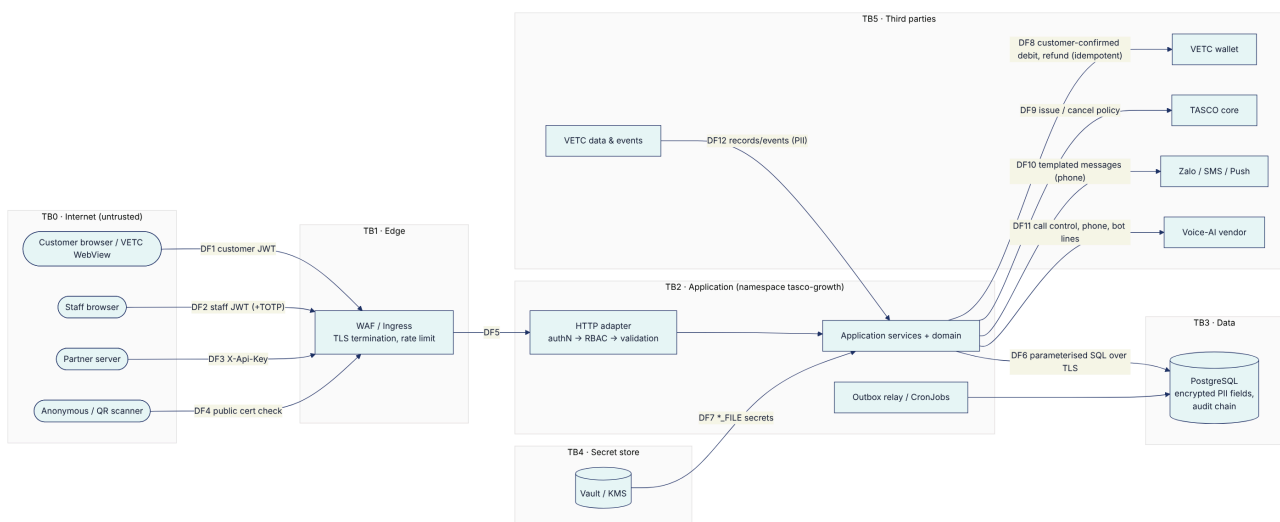
| Document              | Version | Date            | Owner                      | Status                |
|-----------------------|---------|-----------------|----------------------------|-----------------------|
| Security Architecture | 1.0     | 07 October 2026 | iorta TechNXT Architecture | Issued for submission |

Audience: TASCO CISO / InfoSec, VETC security, penetration testers, internal audit. Every control cites the file that implements it. Findings, including those already fixed, are listed openly in section 15. Regulatory references are flagged "**confirm with TASCO legal**".

## 1. Scope and security objectives

| Asset                                                                                                    | Why it matters                                                                                                                      | Primary objective                  |
|----------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------|------------------------------------|
| Personal data of about 6 M vehicle owners (name, phone, plate, consent, engagement, transcripts, claims) | PDP obligations (Decree 13/2023/ND-CP; Law on Personal Data Protection 2025) and customer trust ( <b>confirm with TASCO legal</b> ) | Confidentiality, lawful processing |
| Money movement (customer-confirmed VETC wallet debits, refunds, partner commission)                      | Fraud and double charge                                                                                                             | Integrity, non-repudiation         |
| Regulated rules (tariffs, copy guard, commission caps, consent policy)                                   | Mis-selling and illegal discounts (Law on Insurance Business 08/2022/QH15; <b>confirm with TASCO legal</b> )                        | Integrity, four-eyes               |
| Policies and e-certificates                                                                              | Legal proof of compulsory cover                                                                                                     | Integrity, availability            |
| Audit trail                                                                                              | Accountability for regulators and audit                                                                                             | Integrity (tamper evidence)        |
| Credentials and keys (JWT secret, data keys, blind-index key, partner keys, TOTP seeds)                  | Compromise means full breach                                                                                                        | Confidentiality                    |

## 2. Trust boundaries and data-flow diagram



Each arrow that crosses a trust boundary (TB) authenticates, validates and minimises data. PII crosses into TB5 only on DF10 and DF11 (phone numbers) and DF12 (inbound).

### 3. Threat model (STRIDE)

Ratings: High / Medium / Low residual risk after current controls. "G" references point to the findings register in section 15.

| Component                                                            | S — Spoofing                                                                                  | T — Tampering                                                                               | R — Repudiation                                                          | I — Information disclosure                                   | D — Denial of service                                                              | E — Elevation of privilege                                                                     |
|----------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|--------------------------------------------------------------|------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| <b>Edge / HTTP adapter</b><br>(app.js, security.js)                  | Client IP taken from the right-most trusted X-Forwarded-For hop (L, G1 fixed)                 | TLS at ingress; JSON-only bodies, 1 MiB cap (L)                                             | X-Request-Id on every response and log (L)                               | Generic 500 errors with request id; no stack traces (L)      | Ingress rate limit shared across replicas; in-process limiter per replica (M, G7)  | Route-table auth on every non-public route; malformed path parameters → 400 (L)                |
| <b>Staff identity</b><br>(identityService.js)                        | Password + TOTP for privileged roles; logout covers both steps; TOTP replay rejected (L)      | HS256 with alg pinning and constant-time compare (L)                                        | Logins, failures, lockouts, MFA enrolment and resets audited with IP (L) | Errors do not reveal whether a user exists (L)               | Lockout can be triggered against a known username (M, by design; edge limits)      | No self role or status change; SoD pairs enforced; admins never see TOTP seeds (M, G5 partial) |
| <b>Customer session</b><br>(/api/customer/session, links)            | Signed links expire after LINK_TTL_DAYS (default 30) (L, G11 partial)                         | Link MAC over profile id and expiry (L)                                                     | Customer actions audited with the customer actor (L)                     | Link contains the plate key in clear (M, G11)                | loginLimited per IP (L)                                                            | Customer token cannot reach staff routes (auth: customer); erased subjects lose sessions (L)   |
| <b>Partner API</b><br>(partnerService, /api/partner/v1)              | SHA-256-hashed API keys; partner must be active (M: bearer secret, G8)                        | Idempotency-Key on orders (L)                                                               | actor = partner:<id> in audit (L)                                        | Quote reveals the current expiry of a known plate (M, G8)    | No per-key quota in the app (M, G7)                                                | Key scopes enforced per route; quote and order ownership enforced (L)                          |
| <b>Rules engine / service</b><br>(jsonLogic.js, rulesService.js)     | Approver must be MFA-protected (default MFA_REQUIRED_ROLES) (L)                               | Four-eyes; validation; checksum; operator allow-list; no eval; transactional activation (L) | Every transition audited (L)                                             | Rule payloads limited to rules:read (L)                      | No expression size or depth limit (L, G16)                                         | Restricted kinds approvable only by compliance_officer (L)                                     |
| <b>Sales / payment</b><br>(salesService.js)                          | Only the customer confirms payment, inside the VETC app; staff only send quotes (L, G3 fixed) | Quote claimed atomically (paying) before payment; quote TTL (L, G4 fixed)                   | quote.* and order.* audit (L)                                            | Certificate check masks the plate, no PII (L)                | Breaker isolates wallet and core (L)                                               | No staff path to debit a wallet (L)                                                            |
| <b>Journeys / messaging</b><br>(journeyService.js, contactPolicy.js) | Messages only from official channels and templates (L)                                        | Copy guard at activation and send (L)                                                       | Message log per send (L)                                                 | Message text holds the plate and a link, stored in clear (L) | Frequency caps; CronJob concurrencyPolicy: Forbid (M: double-send if runs overlap) | journeys:run can trigger marketing to any profile within policy (L)                            |

| Component                                              | S — Spoofing                                                                    | T — Tampering                                                                                 | R — Repudiation                           | I — Information disclosure                                                                     | D — Denial of service                                            | E — Elevation of privilege                      |
|--------------------------------------------------------|---------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|-------------------------------------------|------------------------------------------------------------------------------------------------|------------------------------------------------------------------|-------------------------------------------------|
| <b>Voice bot</b> (voicebot.js, voiceService.js)        | Customer proves the plate; bot never reads data; trust line against vishing (L) | Script governed by maker-checker (L)                                                          | voice.call_completed audit (L)            | Transcript encrypted; free-text signals in clear (M, G13); transcript reads region-checked (L) | Breaker, 0 retries (L)                                           | —                                               |
| <b>Persistence</b> (postgresStore.js, codec.js)        | DB TLS with certificate verification; per-workload DB roles (infra) (L)         | Optimistic locking; parameterised SQL; identifier allow-list (L)                              | —                                         | Field-level AES-GCM for PII; blind index (L); plate in clear (M, ADR-006)                      | statement_timeout 15 s; LIMIT ≤ 5,000 (L)                        | No dynamic SQL from input (L)                   |
| <b>Audit log</b> (auditChain.js, migrations)           | —                                                                               | Hash chain; UPDATE/DELETE and TRUNCATE triggers (M: superuser, G12)                           | This is the non-repudiation control       | audit:read only; ids and IP addresses in details (L)                                           | Full-chain verify on the dashboard (L, G12)                      | —                                               |
| <b>Outbox / jobs</b> (outboxEventBus.js, cli.js)       | Jobs use their own ServiceAccount and DB role (infra) (L)                       | Events in DB, claimed with SKIP LOCKED (L)                                                    | actor on events; job runs recorded (L)    | Payloads hold profile ids only (L)                                                             | Stale processing rows reclaimed after 5 min; no backoff (L, G17) | —                                               |
| <b>Outbound integrations</b> (resilience.js, gateways) | mTLS / OAuth2 to providers (target) (M until built)                             | Idempotency keys (M: core per-line key missing)                                               | Provider message ids stored (L)           | Data minimisation per port (L)                                                                 | Timeout + retry + breaker; timeout does not abort (L, G19)       | —                                               |
| <b>SPA / static</b> (public/, serveStatic)             | —                                                                               | Strict CSP, no inline script; path-traversal guard (L)                                        | —                                         | Cache-Control: no-store on API responses (L)                                                   | Static caching (L)                                               | frame-ancestors 'none' against clickjacking (L) |
| <b>Secrets / config</b> (config.js)                    | —                                                                               | Secrets from files; production refuses missing secrets, missing DATABASE_URL or demo mode (L) | —                                         | DEMO_MODE is opt-in (default false) (L, G6 fixed)                                              | —                                                                | —                                               |
| <b>Supply chain / CI</b>                               | Signed images (target) (M)                                                      | One runtime dependency; lockfile; SCA; SAST (L)                                               | Git history; signed commits (recommended) | gitleaks (L)                                                                                   | —                                                                | Admission policy verifies signatures (target)   |

## 4. Zero Trust principles

| Principle                  | Implementation                                                                                                                                                                                                                                                                                                        | Status              |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| Verify explicitly          | JWT verified on every request. The staff user is reloaded on every request ( <code>identityService.authenticate</code> ), and tokens issued before <code>tokensValidAfter</code> are rejected, so password, role, status or region changes apply immediately. Partner key and partner status are checked per request. | Implemented         |
| Least privilege            | 29 fine-grained permissions across 15 roles (section 8); permission-aware ABAC on region and ownership; PII masked unless <code>profile:read_pii</code> ; DB app role without DDL or TRUNCATE (infra)                                                                                                                 | Implemented / infra |
| Assume breach              | Field-level encryption (DB or backup theft yields ciphertext); hash-chained audit; NetworkPolicy default deny; short token TTL; segmented secrets ( <code>BLIND_INDEX_KEY</code> ≠ data keys)                                                                                                                         | Implemented / infra |
| No implicit network trust  | TLS to the DB with certificate verification; mTLS to providers (target); <code>/metrics</code> can require a bearer token ( <code>METRICS_TOKEN</code> ) in addition to network restriction                                                                                                                           | Partial             |
| Device and session posture | Target via IdP conditional access (managed devices for PII roles)                                                                                                                                                                                                                                                     | Planned (ADR-007)   |
| Continuous monitoring      | Audit + metrics + alerts (section 12)                                                                                                                                                                                                                                                                                 | Implemented / infra |

## 5. OWASP Top 10 (2021) control mapping

| ID  | Risk                      | Controls (file)                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Residual / open items                                                                                 |
|-----|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| A01 | Broken Access Control     | Deny by default: each route declares <code>auth</code> and <code>perm</code> ( <code>routes.js</code> ), enforced in <code>app.js</code> → <code>access.require</code> . Permission-aware ABAC ( <code>accessPolicy.check</code> , rule kind <code>abac</code> ). Ownership: customer routes use <code>principal.customerId</code> ; partner data scoped by <code>partnerId</code> ; partner key scopes enforced. Staff vs customer token separation ( <code>aud</code> ). CORS allow-list. | Object-level checks on a few staff routes (G9); privileged role grants without a second approver (G5) |
| A02 | Cryptographic Failures    | AES-256-GCM per field with random 96-bit IV, auth tag and key ids ( <code>crypto.js</code> ); scrypt passwords; SHA-256 API keys; HMAC blind index; TLS to the DB ( <code>rejectUnauthorized: true</code> ); HSTS in production; production refuses missing keys                                                                                                                                                                                                                            | KMS envelope (target); re-key job (planned); plate in clear (ADR-006)                                 |
| A03 | Injection                 | Parameterised SQL only; identifiers from the registry with a regex check; filter and sort columns allow-listed ( <code>query.js</code> , <code>postgresStore.js</code> ). JSON Logic interpreter with an operator allow-list and no <code>eval</code> ( <code>jsonLogic.js</code> ). Allow-list input validation ( <code>validation.js</code> ). DOM via <code>textContent</code> (ADR-011).                                                                                                | Ingest record values are key-allow-listed only (G26)                                                  |
| A04 | Insecure Design           | Threat model (this document); maker-checker; staff never take payment; atomic quote claim; idempotent purchase; saga compensation on issuance failure; state machines; contact policy; copy guard; plate-first voice verification                                                                                                                                                                                                                                                           | Automatic refund retry via the outbox (G18 follow-up)                                                 |
| A05 | Security Misconfiguration | Strict security headers + CSP ( <code>security.js</code> ); X-Powered-By removed; production fail-fast on secrets, database and demo mode ( <code>config.js</code> ); <code>DEMO_MODE</code> opt-in; non-root read-only container; NetworkPolicy (infra); optional <code>METRICS_TOKEN</code>                                                                                                                                                                                               | —                                                                                                     |

| ID  | Risk                                       | Controls (file)                                                                                                                                                                                                                | Residual / open items                                        |
|-----|--------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------|
| A06 | Vulnerable and Outdated Components         | One runtime dependency (pg); <code>npm audit --omit=dev --audit-level=high</code> ; dependency review; Trivy; SBOM; Node 22 LTS; vendored front-end code ( <code>public/vendor/qrcode.mjs</code> , reviewed)                   | Base image patch cadence (monthly rebuild)                   |
| A07 | Identification and Authentication Failures | Password $\geq 12$ characters; scrypt; lockout on password and TOTP steps; TOTP MFA with self-enrolment and replay protection; forced password change for admin-created users; token revocation on credential and role changes | G7 (per-replica logout list), G11, G14 (shared HS256 secret) |
| A08 | Software and Data Integrity Failures       | Rules validated + four-eyes + checksum; one active version per kind (DB index); audit hash chain with UPDATE/DELETE/TRUNCATE triggers; outbox; lockfile; CI gates; image signing (target)                                      | External anchoring of the audit chain (G12)                  |
| A09 | Security Logging and Monitoring Failures   | Hash-chained audit of authentication, consent, DSAR, rules, quotes, orders and views ( <code>profile.viewed</code> with <code>piiVisible</code> ); JSON logs with request id and redaction; metrics and alerts                 | SIEM forwarding and anchoring (target)                       |
| A10 | SSRF                                       | No user-controlled outbound URLs. Provider endpoints come from config. Links are built from <code>PUBLIC_BASE_URL</code> . Egress NetworkPolicy allow-list (infra).                                                            | —                                                            |

## 6. OWASP ASVS L2 summary

Status: ● implemented · ◐ partial · ○ planned · ☐ infrastructure control

| Chapter                                   | Status | Evidence                                                                                                                                                                                           | Open items                                                                                  |
|-------------------------------------------|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| V1 Architecture, design, threat modelling | ◐      | This document; centralised auth pipeline ( <code>app.js</code> ); hexagonal boundaries (ADR-001); route table as a single control point (ADR-010)                                                  | Formal threat-model review each release; security champions                                 |
| V2 Authentication                         | ◐      | 2.1 length-based policy 12–128 ( <code>checkPasswordPolicy</code> ); 2.4 scrypt; 2.2 lockout + audit on both steps; 2.8 TOTP (RFC 6238) with self-enrolment and replay protection (2.8.4)          | 2.1.7 breached-password check; IdP federation (ADR-007)                                     |
| V3 Session management                     | ◐      | Stateless JWT, 30 min TTL, <code>jti</code> ; logout revocation; revocation on password, role, status, region change and MFA reset ( <code>tokensValidAfter</code> ); no cookies (no CSRF surface) | Shared logout denylist (G7); absolute and idle timeouts in the SPA                          |
| V4 Access control                         | ◐      | Deny by default; RBAC + permission-aware ABAC; server-side ownership checks; PII masking by permission; SoD pairs                                                                                  | Object-level checks on remaining staff routes (G9); maker-checker on privileged grants (G5) |
| V5 Validation, sanitisation, encoding     | ●      | Allow-list schemas with length bounds and enums; JSON-only; parameterised SQL; safe rule interpreter; DOM <code>textContent</code>                                                                 | Typed schema for ingest records (G26)                                                       |
| V6 Stored cryptography                    | ◐      | AES-256-GCM, random IVs, key ids and rotation; scrypt; secrets from files                                                                                                                          | KMS-wrapped keys; re-key and blind-index rotation jobs                                      |
| V7 Error handling and logging             | ●      | Generic errors with request id; structured JSON logs; PII redaction; audit chain                                                                                                                   | SIEM integration; log integrity outside the DB                                              |

| Chapter                 | Status | Evidence                                                                                                                                                                                                  | Open items                                                          |
|-------------------------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|
| V8 Data protection      | •      | Field encryption; masking ( <code>maskProfile</code> , <code>maskPhone</code> , <code>maskPlate</code> ); no-store; DSAR export and erase (including handoffs, claims and voice signals); retention rules | Encryption of free-text voice signals (G13); legal hold flag        |
| V9 Communication        | □      | TLS at ingress (1.2+), HSTS, TLS to the DB with verification                                                                                                                                              | mTLS to providers                                                   |
| V10 Malicious code      | •      | Minimal dependencies; SAST; SCA; secret scanning; no dynamic code execution                                                                                                                               | Subresource integrity is not applicable (no CDN scripts)            |
| V11 Business logic      | •      | Maker-checker; customer-only payment; atomic quote claim; idempotency; quote TTL; inspection gate for physical damage cover; contact caps; copy guard; statutory caps                                     | G16 follow-ups                                                      |
| V12 Files and resources | •      | No file uploads today (claims capture a photo count only); static path-traversal guard; body limit                                                                                                        | Claim photo upload: pre-signed URLs, AV scan, type checks (planned) |
| V13 API and web service | •      | OpenAPI generated from code; JSON content-type enforcement; <code>additionalProperties: false</code> ; idempotency headers; partner API versioned with enforced key scopes                                | Per-key quotas (G7); response schemas                               |
| V14 Configuration       | •      | Security headers/CSP; production fail-fast; demo mode opt-in; non-root, read-only container (□); SBOM; secrets as files                                                                                   | —                                                                   |

## 7. Identity, authentication, MFA and session management

| Item             | Current                                                                                                                                                                                                                                                                                              | Target                                                   |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|
| Staff login      | Username + password (script N=16384, r=8, p=1) → MFA step for <code>MFA_REQUIRED_ROLES</code> (default admin, rule_approver, compliance_officer, data_steward) or enrolled users. Users created by an administrator must change their password at first sign-in ( <code>mustChangePassword</code> ). | OIDC + PKCE to the TASCO IdP; MFA via conditional access |
| MFA enrolment    | Self-enrolment at first sign-in: the QR code / <code>otpauth</code> URI is shown only to the user who has just proved the password. Administrators never see seeds. <code>POST /api/users/:id/reset {resetMfa}</code> forces re-enrolment.                                                           | WebAuthn for administrators                              |
| MFA verification | TOTP SHA-1, 6 digits, 30 s, ±1 step; <code>mfaToken</code> JWT <code>aud=mfa</code> , 5 min. A code cannot be reused ( <code>lastTotpStep</code> ). The lock is checked and failures count towards logout.                                                                                           | Single-use <code>mfaToken</code> nonce                   |
| Lockout          | 5 failures → 15 min, covering password and code steps; audited ( <code>auth.login_failed</code> , <code>auth.login_locked</code> , <code>auth.mfa_failed</code> ). <code>POST /api/users/:id/reset {unlock}</code> for the service desk; an administrator cannot reset their own account.            | Progressive delays; alerting on spray patterns           |
| Access token     | HS256 JWT, <code>aud=staff</code> , <code>roles</code> , <code>region</code> , <code>amr</code> , <code>jti</code> , 30 min                                                                                                                                                                          | RS256/ES256 from the IdP, validated via JWKS             |

| Item                           | Current                                                                                                                                                                                                                                                        | Target                                                                                                                                                       |
|--------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Revocation                     | Password change, MFA reset, and role, status or region change set <code>tokensValidAfter</code> , which is persisted and therefore effective on every replica. <code>POST /api/auth/logout</code> adds the <code>jti</code> to an in-memory map (per replica). | Shared denylist (Redis) or IdP session revocation                                                                                                            |
| Customer                       | Signed link ( <code>&lt;profileId&gt;.&lt;expiry&gt;.&lt;MAC&gt;</code> , <code>LINK_TTL_DAYS</code> default 30) → customer JWT (1 h). Erased data subjects lose their sessions. Demo: <code>demoProfileId</code> only when <code>DEMO_MODE</code> is on.      | VETC SSO token exchange                                                                                                                                      |
| Partner                        | X-Api-Key (SHA-256 stored), revocable; scopes <code>quote</code> , <code>purchase</code> , <code>policies:read</code> enforced per route                                                                                                                       | OAuth2 client credentials or mTLS                                                                                                                            |
| Recommended MFA_REQUIRED_ROLES | —                                                                                                                                                                                                                                                              | Add <code>telesales_supervisor</code> , <code>partner_manager</code> and <code>support_engineer</code> . Ideally MFA for all staff once the IdP is in place. |

UAT-only settings ( `DEMO_PASSWORD` , `DEMO_TOTP_SEED` , `DEMO_ACCOUNT_SYNC` ) exist so testers can sign in to the hosted UAT with published demonstration authenticator keys. They take effect only with `DEMO_MODE` on, which production refuses. The UAT password is distributed in the access workbook and is never written in documents.

## 8. Authorisation: RBAC and ABAC

Authorisation is evaluated in two steps: role-based permissions (RBAC), then attribute-based policies (ABAC) on the specific resource.

### 8.1 RBAC matrix

Source: `config/security/rbac.json` . It is changed only through code review and CAB; it is deliberately not a business rule kind.

| Role                 | Permissions                                                                                                                                                                                                                     |
|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| admin                | <code>users:manage</code> , <code>ops:read</code> , <code>ops:run_jobs</code> , <code>audit:read</code> , <code>rules:read</code> , <code>dashboard:read</code>                                                                 |
| executive            | <code>dashboard:read</code>                                                                                                                                                                                                     |
| campaign_manager     | <code>dashboard:read</code> , <code>leads:read</code> , <code>leads:recompute</code> , <code>journeys:run</code> , <code>profile:read</code> , <code>voice:operate</code> , <code>rules:read</code> , <code>handoff:read</code> |
| telesales_agent      | <code>handoff:read</code> , <code>handoff:work</code> , <code>profile:read</code> , <code>profile:read_pii</code> , <code>quote:create</code> , <code>policy:read</code> , <code>voice:operate</code> , <code>leads:read</code> |
| telesales_supervisor | As <code>telesales_agent</code> , plus <code>handoff:assign</code> and <code>dashboard:read</code>                                                                                                                              |
| rule_author          | <code>rules:read</code> , <code>rules:author</code> , <code>dashboard:read</code>                                                                                                                                               |
| rule_approver        | <code>rules:read</code> , <code>rules:approve</code> , <code>audit:read</code> , <code>dashboard:read</code>                                                                                                                    |
| compliance_officer   | <code>rules:read</code> , <code>rules:approve</code> , <code>audit:read</code> , <code>dashboard:read</code> , <code>dsar:manage</code> , <code>profile:read</code>                                                             |
| data_steward         | <code>dq:read</code> , <code>dq:resolve</code> , <code>profile:read</code> , <code>profile:read_pii</code> , <code>profile:update</code> , <code>data:ingest</code> , <code>leads:read</code> , <code>dashboard:read</code>     |
| claims_handler       | <code>claims:read</code> , <code>claims:update</code> , <code>policy:read</code> , <code>profile:read</code>                                                                                                                    |
| partner_manager      | <code>partners:manage</code> , <code>dashboard:read</code> , <code>policy:read</code>                                                                                                                                           |

| Role             | Permissions                            |
|------------------|----------------------------------------|
| auditor          | audit:read, rules:read, dashboard:read |
| support_engineer | ops:read, ops:run_jobs                 |
| customer         | customer:self                          |
| partner_api      | partner:transact                       |

No role can take payment: `quote:create` lets telesales quote and send the quote to the customer ( `POST /api/quotes/:id/send` ); the customer confirms and pays inside the VETC app. The former `policy:issue` permission has been removed.

Segregation of duties:

- **Forbidden role combinations** are declared in `rbac.json` ( `separationOfDuties` ) and enforced when users are created or updated ( `identityService.assertSoD` ). Examples: admin + rule\_approver, admin + data\_steward, rule\_author + rule\_approver, rule\_author + compliance\_officer.
- **No self-administration**: a user cannot change their own roles or status, and an administrator cannot reset their own account.
- **Four-eyes on rules**: no role holds both `rules:author` and `rules:approve` , and `rulesService` also blocks self-approval.
- **Restricted rule kinds** ( `abac` , `copy_guard` , `contact_policy` , `commission` , `retention` ) can be approved only by `compliance_officer` ( `restrictedRuleKinds` ).
- The admin has no `profile:read_pii` , `rules:author` or `rules:approve` ; an auditor is read-only.

`customer:self` is declared but not checked by any route; customer routes rely on `auth: 'customer'` plus `principal.customerId`.

Route → permission mapping: 80 operations (6 public, 60 staff, 10 customer, 4 partner), listed in `/api/openapi.json` under `x-permission` and `x-audience`.

## 8.2 ABAC policies ( `config/rules/abac.json` , rule kind `abac` )

| Policy             | Resource / actions            | Applies to roles                                    | Allow condition                                                                                 |
|--------------------|-------------------------------|-----------------------------------------------------|-------------------------------------------------------------------------------------------------|
| agent_own_handoffs | handoff: read, update         | telesales_agent                                     | Assigned to the user or unassigned, AND the user's region is ALL or matches the resource region |
| regional_data      | profile: read, update         | telesales_agent, telesales_supervisor, data_steward | <code>user.region = 'ALL'</code> OR <code>user.region = resource.region</code>                  |
| customer_self      | customer_self: read, purchase | customer                                            | <code>resource.ownerId = user.customerId</code> (declared; ownership is enforced in route code) |

How evaluation works ( `accessPolicy.check` ):

- ABAC runs after RBAC, only for policies whose `resource` and `action` match.
- A policy restricts any principal holding one of its `appliesToRoles` . It is skipped only when another, out-of-scope role **independently grants the policy's permission** (for example a supervisor-level role). Adding an unrelated role, such as `executive` , never widens data access (G10 fixed).

- The handoff list is filtered per item. Profile-level checks run on the customer 360, lineage, expiry correction, quote creation, quote sending and voice session start and read.

### 8.3 PII masking

`maskProfile` (`accessPolicy.js`): without `profile:read_pii`, the name becomes `N. V. An` -style initials and phones become `0912***678` (`util.maskName`, `maskPhone`), with `piiMasked: true`.

Other masking:

- message `to` is hidden without PII permission;
- handoffs carry only a masked phone;
- the voice bot speaks a masked plate (`maskPlate` → `30A-***.45`);
- the public certificate check returns a masked plate.

Every customer-360 view is audited as `profile.viewed {piiVisible}`.

## 9. Cryptography and key management

| Purpose                         | Algorithm / parameters                                                                                                                                | Key / secret                                | Rotation                                                             |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|----------------------------------------------------------------------|
| PII at rest                     | AES-256-GCM, 12-byte random IV, 16-byte tag, <code>enc:v1:&lt;kid&gt;:...</code>                                                                      | DATA_KEYS (32 bytes each), DATA_KEY_ACTIVE  | Add a key, switch active, re-key job (planned), retire. Yearly.      |
| Equality search on phone        | HMAC-SHA256 (lower-cased value)                                                                                                                       | BLIND_INDEX_KEY (32 bytes)                  | On compromise only; recompute <code>*_bidx</code>                    |
| Staff passwords                 | scrypt $N=2^{14}$ , $r=8$ , $p=1$ , 16-byte salt, 64-byte output; <code>timingSafeEqual</code>                                                        | Per-user salt                               | Rehash on login when parameters change (planned)                     |
| Access, MFA and customer tokens | HMAC-SHA256 JWT (HS256 only; alg pinned)                                                                                                              | JWT_SECRET ( $\geq 48$ bytes)               | 90 days (invalidates sessions and links); target IdP asymmetric keys |
| Renewal links                   | HMAC-SHA256 over <code>&lt;profileId&gt; . &lt;expiry&gt;</code> , truncated to 22 base64url characters (132 bits); expiry <code>LINK_TTL_DAYS</code> | <code>sha256("links:" + JWT_SECRET)</code>  | Tied to JWT_SECRET (separate key recommended, G11)                   |
| Partner API keys                | 24 random bytes ( <code>tpk_...</code> ), stored as SHA-256                                                                                           | —                                           | $\leq 12$ months; revoke on demand                                   |
| TOTP                            | HMAC-SHA1 (RFC 6238), 160-bit seed                                                                                                                    | Per user, encrypted at rest                 | Re-enrol on device loss ( <code>resetMfa</code> )                    |
| Audit chain                     | SHA-256 over canonical JSON                                                                                                                           | —                                           | Not applicable; external anchoring (target)                          |
| Transport                       | TLS 1.2+ (ingress), TLS with verification to PostgreSQL                                                                                               | Certificates via cert-manager / provider CA | Automated                                                            |

Key custody:

- **Today:** keys are mounted as files from the secret store and live in process memory.
- **Target:** DEKs wrapped by a KMS/HSM KEK and unwrapped at boot via workload identity. KMS audit logs track key use. Keys stay in a Vietnamese region (**confirm with TASCO legal**).

## 10. Secrets management

- **Delivery:** `<NAME>_FILE` ( `config.js#readSecret` ) from External Secrets Operator → Vault or cloud secret manager, mounted read-only (0400). Environment literals are used only on Railway (UAT and pilots), with synthetic data.
- **Fail-fast:** production throws at boot if `JWT_SECRET`, `BLIND_INDEX_KEY` or `DATA_KEYS` are missing, if a data key is not 32 bytes, if `DATA_KEY_ACTIVE` is unknown, if `DATABASE_URL` is missing (no in-memory store in production), or if `DEMO_MODE` is on without `ALLOW_DEMO_IN_PRODUCTION`.
- **Non-production:** missing secrets get ephemeral random values plus a startup warning ( `config.warnings` ). Data encrypted with an ephemeral key is unreadable after a restart. That is acceptable only with the in-memory store.
- **Hygiene:** gitleaks in CI; no secrets in images (multi-stage build, `.dockerignore` ); the logger redacts `secret`, `token`, `apiKey` and `authorization` keys.

Rotation procedures are in section 8 of the [Deployment and Infrastructure Architecture](#).

## 11. Input validation, data access and PII handling

- **Validation** ( `src/shared/validation.js` ):
  - allow-list per route;
  - unknown properties are rejected (this also neutralises `__proto__` keys);
  - strings are bounded (default maximum 1,000);
  - enums, patterns (ids `^[A-Za-z0-9_\-: @. ]+$`), integer ranges and ISO dates are checked;
  - arrays are length-bounded;
  - malformed path parameters return 400 ( `router.js` ).

Bodies must be JSON objects  $\leq 1$  MiB with `Content-Type: application/json` ( `app.js#readBody` ). Free-form `object` fields (rule payloads) go through the per-kind validator instead.

- **Domain normalisation:** plates and phones are normalised and validated before use ( `identity.js` ). Customer utterances are capped at 500 characters in transcripts and 200 in signals.
- **Data access:** only `$n` -parameterised statements. No string-built SQL from input. `LIMIT`  $\leq 5,000$ , offsets  $\geq 0$ .
- **Output:** JSON with `Cache-Control: no-store`. The SPA renders with `textContent`.
- **PII handling rules:**
  1. Collect the minimum (the ingest allow-list excludes national id, address and date of birth).
  2. Encrypt Restricted fields (section 4 of the [Data Architecture](#)).
  3. Mask by default.
  4. Keep PII out of audit details and logs.
  5. Apply retention by rule.
  6. Support DSAR export and erase ( `/api/dsar/*`, `/api/customer/data-export` ).
  7. Disclose AI use (voice bot), see [AI and Prompt Governance](#).

## 12. Security logging, monitoring and audit

**Audit events** (hash-chained, `auditService.record`):

- **Authentication:** `auth.login`, `auth.login_failed`, `auth.login_locked`, `auth.mfa_failed`, `auth.mfa_enrolled`, `auth.password_changed`
- **Users and partners:** `user.created`, `user.updated`, `user.reset`, `partner.created`, `partner.status_changed`, `partner.api_key_issued`, `partner.api_key_revoked`
- **Rules:** `rules.seeded`, `rules.draft_created`, `rules.submitted`, `rules.approved`, `rules.rejected`
- **Data:** `data.ingested`, `profile.viewed`, `profile.expiry_corrected`, `customer.expiry_declared`, `consent.updated`, `consent.withdrawn`, `dsar.access_exported`, `dsar.erased`, `dq.resolved`
- **Commerce:** `quote.created`, `quote.inspection_recorded`, `quote.sent_to_customer`, `order.completed`, `order.payment_failed`, `order.issuance_failed`, `claim.submitted`, `claim.status_changed`
- **Engagement and jobs:** `voice.call_completed`, `handoff.updated`, `journeys.run`, `ecosystem.event_handled`, `leads.recomputed`, `job.*`
- **UAT only:** `demo.accounts_synced` (written when `DEMO_ACCOUNT_SYNC` resets demonstration accounts at start-up)

**Security monitoring** (alert rules in section 15 of the [Deployment and Infrastructure Architecture](#)):

- login failure and logout spikes;
- 401/403/429 anomalies per route;
- partner key misuse (403s and 429s per partner);
- a failed audit-chain probe;
- DSAR erase volume;
- off-hours rule approvals;
- `users:manage` actions (always notify the security mailbox);
- a breaker open on payment;
- orders in `compensation_failed` (reconciliation).

**SIEM (target):** forward JSON logs and a periodic export of the audit log, plus the hourly chain-head anchor, to the TASCO SIEM and WORM storage.

## 13. Secure SDLC: scanning in CI

Pipeline: `.github/workflows/ci.yml`; see section 9 of the [Deployment and Infrastructure Architecture](#).

| Control                                                          | Tool                                                                                         | Gate                |
|------------------------------------------------------------------|----------------------------------------------------------------------------------------------|---------------------|
| Lint (including <code>no-eval</code> -style rules)               | ESLint 9                                                                                     | Errors fail         |
| Unit, integration, API, security and functional tests + coverage | <code>node --test (test:coverage gates lines 80 % / branches 70 % / functions 80 %)</code>   | Failures fail       |
| PostgreSQL behaviour                                             | <code>test:pg</code> against a PostgreSQL service container                                  | Failures fail       |
| OpenAPI contract                                                 | Generated spec compared with <code>docs/api/openapi.json</code>                              | Drift fails         |
| Performance smoke                                                | <code>test:perf</code> (p95 budget)                                                          | Budget breach fails |
| SAST                                                             | GitHub CodeQL (JavaScript)                                                                   | New high/critical   |
| SCA                                                              | <code>npm audit --omit=dev --audit-level=high</code> ; <code>dependency-review</code> action | High and above      |
| Secrets                                                          | <code>gitleaks</code>                                                                        | Any finding         |

| Control   | Tool                                                                                                                                                                                                                  | Gate                            |
|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|
| Container | Trivy (OS + npm)                                                                                                                                                                                                      | HIGH/CRITICAL with a fix        |
| DAST      | OWASP ZAP baseline (spec-driven via <code>/api/openapi.json</code> )                                                                                                                                                  | High alerts                     |
| SBOM      | CycloneDX attached to the build                                                                                                                                                                                       | Must exist                      |
| Review    | Security reviewer required for <code>src/shared/crypto.js</code> , <code>src/adapters/http/*</code> , <code>config/security/*</code> and <code>db/migrations/*</code> (CODEOWNERS file to be added to the repository) | Required approval (recommended) |

Latest recorded run (07 October 2026): 238 tests, 235 passed, 0 failed, 3 marked to-do (manual or roadmap scenarios); coverage 99.5 % lines, 91.6 % branches, 97.2 % functions; ESLint 0 errors. Details are in the test cases and results workbook ([docs/quality/TASCO-Test-Cases-and-Results.xlsx](#)).

## 14. Penetration-test readiness checklist

- ☐ Test environment = SIT with `NODE_ENV=production`, `DEMO_MODE=false`, real TLS, behind the production-like ingress/WAF (with a WAF bypass list for the tester's IPs, to test the application itself)
- ☐ Test accounts for **every role** (15), MFA-enrolled where required, plus 2 partners (active + suspended) with keys, and customer links for 3 profiles in different regions
- ☐ OpenAPI specification exported (`npm run job -- openapi`) and shared; route permission matrix (section 8) shared
- ☐ Synthetic dataset loaded ( $\geq 50$  k profiles) with known PII markers to detect leakage
- ☐ Sandbox gateways configured with fault injection (`failRate`) for business-logic tests (compensation, idempotency)
- ☐ In-scope focus list: authentication and MFA (self-enrolment, replay, logout), object-level access (G9), purchase concurrency and idempotency, partner API scopes and data exposure (G8), rules engine injection and maker-checker bypass, customer link forgery and expiry (G11), audit-chain tampering (G12), CSP/XSS in the SPA, DSAR completeness (G13)
- ☐ Out of scope / provider-owned: VETC wallet, TASCO core, Zalo, telco
- ☐ Logging verified: testers' actions appear in the audit chain and logs with request ids; SOC informed of the test window
- ☐ Rollback and data reset plan (`store.reset()` only in test environments)
- ☐ Findings register (section 15) shared up front, so testing time goes to unknowns

## 15. Findings register and remediation plan

Finding IDs are stable across reviews; numbers missing from the sequence were closed before this issue. "Fixed" means remediated in code and covered by automated tests; the mechanism is named.

| ID | Severity | Finding (file)                                                                                                                                  | Status and mechanism / remaining action                                                                                                                         | Phase |
|----|----------|-------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|
| G1 | High     | <code>clientIp()</code> trusted the left-most X-Forwarded-For value ( <code>app.js</code> ), allowing IP spoofing against rate limits and audit | <b>Fixed.</b> The right-most trusted hop is used ( <code>TRUST_PROXY_HOPS</code> , default 1); the ingress overwrites XFF and applies a shared edge rate limit. | Done  |

| ID  | Severity | Finding (file)                                                                                                                      | Status and mechanism / remaining action                                                                                                                                                                                                                                                           | Phase                  |
|-----|----------|-------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
| G2  | High     | verifyMfa did not check lockedUntil (identityService.js), so TOTP guessing could continue during logout                             | <b>Fixed.</b> The lock is checked in verifyMfa; code failures count towards the same logout; reused codes are rejected. Residual: single-use mfaToken nonce (Low).                                                                                                                                | Done                   |
| G3  | High     | Staff POST /api/orders (policy:issue) could debit a customer's VETC wallet without customer confirmation                            | <b>Fixed.</b> The endpoint and policy:issue are removed. Staff quote and send (POST /api/quotes/:id/send); only the customer can pay (POST /api/customer/orders); salesService.purchase refuses a wallet debit for any non-customer actor. Partner sales are partner-collected (no wallet debit). | Done                   |
| G4  | High     | Concurrent purchases of one quote with different Idempotency-Keys could both pass the open check (double debit)                     | <b>Fixed.</b> The quote is claimed atomically (status paying, optimistic version check) before payment; a concurrent attempt receives 409. Reusing the key of a failed attempt also returns 409.                                                                                                  | Done                   |
| G5  | High     | users:manage could assign any role, including to oneself (identityService.update, createUser)                                       | <b>Partially fixed.</b> Self role and status changes are forbidden; SoD pairs are enforced; administrators cannot reset their own account. Open: a second approver for privileged role grants and an alert on every grant.                                                                        | Before production      |
| G30 | High     | createUser returned the new user's TOTP secret to the creating administrator, enabling impersonation                                | <b>Fixed.</b> Users self-enrol at first sign-in (QR shown only to the user); administrators never see seeds; admin-created users must change their password at first sign-in; POST /api/users/:id/reset forces re-enrolment.                                                                      | Done                   |
| G6  | Medium   | DEMO_MODE defaulted to true outside production, exposing /api/demo/totp/:username and demo customer login                           | <b>Fixed.</b> DEMO_MODE is opt-in (default false); production refuses it unless ALLOW_DEMO_IN_PRODUCTION; demo-only routes return 404 when it is off. The hosted UAT enables it deliberately, with synthetic data only.                                                                           | Done                   |
| G7  | Medium   | Rate limiter and logout revocation are in-process, per replica (security.js, identityService)                                       | <b>Partially fixed.</b> Edge rate limiting at the ingress (shared); credential, role and status changes revoke tokens through the persisted tokensValidAfter. Open: shared logout denylist; per-partner quotas at the gateway.                                                                    | Phase 2                |
| G8  | Medium   | Partner API: scopes not enforced; quotes reveal current expiry; partner facts influence the golden record; consentMarketing ignored | <b>Partially fixed.</b> Scopes are enforced per route; consentMarketing is removed from the schema; partner-declared expiry is unverified, trust-weighted evidence. Open: quotes for existing plates still reveal cover start; quarantine partner contact data.                                   | Before partner go-live |
| G9  | Medium   | Missing object-level checks on several staff routes                                                                                 | <b>Partially fixed.</b> Region checks now apply to lineage, expiry correction, quote creation and sending, and voice session start and read. Open: GET /api/policies, POST /api/voice/sessions/:id/turns, POST /api/rules/simulate; declarative abac field in the route table.                    | Phase 2                |
| G10 | Medium   | ABAC policies were skipped for users holding any additional role (accessPolicy.check)                                               | <b>Fixed.</b> A policy is skipped only when another role independently grants the policy's permission.                                                                                                                                                                                            | Done                   |
| G11 | Medium   | Renewal links never expired, embedded the plate key and used a key derived from JWT_SECRET; customer tokens survived erasure        | <b>Partially fixed.</b> Links carry a signed expiry (LINK_TTL_DAYS, default 30) and a 132-bit MAC; erased data subjects lose their sessions. Open: pseudonymous id instead of the plate key; separate LINK_KEY; nonce.                                                                            | Phase 2                |

| ID  | Severity | Finding (file)                                                                                                                                                      | Status and mechanism / remaining action                                                                                                                                                                                                                                | Phase                               |
|-----|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|
| G12 | Medium   | Audit: TRUNCATE bypassed the row trigger; a superuser can rewrite the chain; full-chain verify on each dashboard call; audit write outside the business transaction | <b>Partially fixed.</b> Migration <code>002_integrity_hardening.sql</code> adds a statement-level TRUNCATE block. Open: DB role separation (infra); hourly external anchoring; incremental verification; transactional audit.                                          | Before production (roles) / Phase 2 |
| G13 | Medium   | Free-text speech stored in clear; erasure missed handoffs and free-text fields; DSAR export omitted quotes, orders, claims and handoffs                             | <b>Partially fixed.</b> Erasure now scrubs handoffs, claim text, voice transcripts and signals, and <code>competitorNote</code> ; DSAR export includes quotes, orders, claims and telesales tasks. Open: encrypt free-text signals or store structured values only.    | Phase 2                             |
| G14 | Low      | TOTP replay within $\pm 30$ s; password change did not invalidate tokens; one HS256 secret for all audiences                                                        | <b>Partially fixed.</b> <code>lastTotpStep</code> blocks replay; <code>tokensValidAfter</code> revokes tokens on password change. Open: one shared HS256 secret (target: IdP asymmetric tokens).                                                                       | Phase 2                             |
| G15 | Low      | <code>/metrics</code> unauthenticated on the application port                                                                                                       | <b>Fixed.</b> Optional <code>METRICS_TOKEN</code> bearer token ( <code>app.js</code> ), plus <code>NetworkPolicy</code> and ingress block (infra).                                                                                                                     | Done                                |
| G16 | Low      | Non-atomic rule activation; string-matching commission cap validator; no per-kind approver roles; no expression size limit                                          | <b>Partially fixed.</b> Activation runs in a transaction with a unique index on the active version per kind (migration 002); restricted kinds need <code>compliance_officer</code> . Open: evaluate each commission row against each capped product; node-count limit. | Phase 2                             |
| G17 | Low      | Outbox: stuck <code>processing</code> rows after a crash; no backoff; event-driven sends not deduplicated                                                           | <b>Partially fixed.</b> <code>claimEvents</code> reclaims <code>processing</code> rows older than 5 minutes, supported by a status index (migration 002). Open: <code>next_attempt_at</code> backoff; deterministic message ids.                                       | Phase 2                             |
| G18 | Low      | Refund on issuance failure bypassed the breaker and swallowed errors                                                                                                | <b>Fixed.</b> Saga compensation cancels issued lines and refunds through the payment breaker; failures set <code>compensation_failed</code> , which reconciliation flags. Follow-up: automatic refund retry via the outbox.                                            | Done (retry Phase 2)                |
| G19 | Low      | <code>withTimeout</code> does not abort the underlying request                                                                                                      | <b>Open.</b> Use <code>AbortSignal</code> in the real adapters.                                                                                                                                                                                                        | With real adapters                  |
| G21 | Low      | <code>migrate()</code> had no advisory lock; <code>MIGRATE_ON_START</code> defaults on                                                                              | <b>Fixed.</b> <code>migrate()</code> takes <code>pg_advisory_lock</code> ; Kubernetes sets <code>MIGRATE_ON_START=false</code> and Railway runs <code>migrate</code> as a pre-deploy command.                                                                          | Done                                |
| G23 | Low      | Malformed percent-encoding in a path parameter caused an unhandled 500 ( <code>router.match</code> )                                                                | <b>Fixed.</b> The router returns 400.                                                                                                                                                                                                                                  | Done                                |
| G26 | Low      | <code>POST /api/data/ingest</code> allow-lists record keys but not value types or lengths                                                                           | <b>Open.</b> Typed record schema.                                                                                                                                                                                                                                      | Phase 2                             |

## 16. Security incident response outline



| Step                 | Platform-specific actions                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Contain              | Revoke partner keys ( <code>DELETE /api/partners/keys/:keyId</code> ); suspend partners ( <code>PATCH /api/partners/:id</code> ); disable users ( <code>PATCH /api/users/:id {status: disabled}</code> , effective on the next request); force MFA re-enrolment ( <code>POST /api/users/:id/reset {resetMfa}</code> ). Suspend journeys by setting the CronJob to <code>suspend: true</code> . Rotate <code>JWT_SECRET</code> to end all sessions and links. Roll back a rule set ( <code>/api/rules/:id/rollback</code> , then <code>approve</code> ). |
| Investigate          | <code>GET /api/audit?actor=...&amp;action=...</code> ; <code>/api/audit/verify (integrity)</code> ; request-id correlation across logs; messages and voice_sessions for customer impact                                                                                                                                                                                                                                                                                                                                                                 |
| Personal data breach | Assess scope via the audit trail ( <code>profile.viewed</code> with <code>piiVisible</code> , <code>dsar.*</code> ). Notify the competent authority (Ministry of Public Security / A05) within <b>72 hours</b> of discovery, per Decree 13/2023/ND-CP (and the PDP Law 2025 implementing rules), and notify affected data subjects where required ( <b>confirm deadlines and channel with TASCO legal</b> ).                                                                                                                                            |
| Evidence             | Preserve the audit-chain head hash, logs (WORM), DB snapshot and Kubernetes events. Keep a chain of custody.                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Communication        | A pre-approved holding statement for customers emphasising "VETC never asks for OTP or payment by phone" (vishing incidents)                                                                                                                                                                                                                                                                                                                                                                                                                            |